Information Security Policy

1. Purpose and scope

This policy applies to every Northwind employee and contractor, and to every system that stores or processes customer data. Violations may lead to disciplinary action.

2. Secrets management

2.1 Where secrets live

All secrets, including database passwords, service credentials and signing keys, are stored in Vault at vault.nw.internal. Secrets must never be committed to source control, pasted into chat or tickets, or stored in configuration files. CI scans every pull request for secrets and blocks the merge if it finds one.

2.2 Rotation

Service credentials are rotated automatically every 90 days. Any secret that may have been exposed must be rotated immediately and the exposure reported as a security incident.

2.3 Customer API keys

Customer API keys are prefixed nw_live_ for production and nw_test_ for the sandbox, so they are easy to recognize in leaked text. Northwind participates in GitHub secret scanning: keys found in public repositories are revoked automatically and the account Owners are emailed.

3. Devices

Laptops must have full-disk encryption, automatic screen lock after 5 minutes, and the endpoint protection agent installed. Lost or stolen devices must be reported to IT within 1 hour so they can be wiped remotely.

4. Reporting security incidents

Report any suspected security incident, including phishing emails you clicked on, to security@northwind.example or in the #sec-incidents channel within 1 hour of noticing it. You will never be blamed for reporting in good faith.

5. Vulnerability management

Vulnerabilities in Northwind systems and their dependencies must be fixed within these deadlines, counted from when they are found:

- Critical: 7 days
- High: 30 days
- Medium: 90 days
- Low: next planned maintenance

Exceptions require written approval from the Head of Security.

6. Review

This policy is reviewed every year by the Security team.